

Postal Address:

Box 8114

104 20 Stockholm

Website:

www.imy.se

Email:

imy@imy.se

Phone:

08-657 61 00

1(15)

Avanza Bank AB

Regeringsgatan 103

111 39 Stockholm

Decision following supervision under the
Data Protection Regulation against Avanza
Bank AB

Decision of the Swedish Authority for Privacy Protection

The Swedish Authority for Privacy Protection (Integritetsskyddsmyndigheten) finds that Avanza Bank AB (organization number 556573-5668) has processed personal data in violation of Articles 5.1(f) and 32.1 of the Data Protection Regulation by failing to take appropriate technical and organizational measures to ensure a suitable level of security for personal data during the period from November 15, 2019, to June 2, 2021, when using the analytical tool Meta-pixel.

The Swedish Authority for Privacy Protection decides, based on Articles 58.2 and 83 of the Data Protection Regulation, that Avanza Bank AB shall pay an administrative fine of 15,000,000 (fifteen million) kronor for the violations of Articles 5.1(f) and 32.1 of the Data Protection Regulation.

Account of the supervisory case

Starting point for the supervision

The Swedish Authority for Privacy Protection (IMY) received a report of a personal data incident from Avanza Bank AB (the bank) on June 8, 2021. The report indicated that personal data concerning 500,001 – 1 million individuals had been incorrectly transferred to the bank's partner Facebook (now Meta) during the period from November 15, 2019, to June 2, 2021. Among the data transferred were personal identification numbers, loan amounts, and account numbers.

The background to the incident was that the bank had begun using Meta's service Facebook-pixel (now Meta-pixel) to optimize the bank's marketing. In 2019, Meta developed a new sub-function within the Meta-pixel, called Automatic Advanced Matching (AAM). The incorrect transfer of personal data was caused by the bank mistakenly activating the new AAM function. The bank became aware of the transfer through external information. As soon as the bank became aware of the incident, it deactivated the Meta-pixel entirely.

1 Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

Case number:

DI-2021-5544

Date:

2024-06-24

Swedish Authority for Privacy Protection

Case number: DI-2021-5544

2(15)

Date: 2024-06-24

In light of the information in the report of the personal data incident, IMY initiated supervision of the

bank. The supervision has been limited to examining the extent to which the bank has taken appropriate technical and organizational measures to protect the personal data of website visitors and app users in accordance with Articles 5.1(f) and 32.1 of the Data Protection Regulation during the period from November 15, 2019, to June 2, 2021.

What the bank has stated

The bank has primarily stated the following regarding the issues under IMY's review.

Data Controller

The bank is the data controller for the implementation of the Meta-pixel and the subsequent transfer of personal data to Meta.

The original implementation of the Meta-pixel

The bank has procedures in place to ensure the correct processing of personal data before, during, and after the implementation of new features on the website. These procedures are formalized and documented in the bank's governing documents. According to the bank's procedures for ensuring correct processing of personal data, a review and assessment of the planned processing must initially be conducted before any new or changed personal data processing to ensure that it meets the requirements of the Data Protection Regulation. The review is conducted using, among other things, a documented template for personal data processing, which contains several steps that the employee responsible for implementing a new or changed personal data processing must go through. The steps include conducting a risk analysis of the processing, establishing a legal basis, and ensuring that the data subjects are provided with correct information about the new personal data processing.

Furthermore, the processing must be recorded in the bank's register of processing activities.

The Meta-pixel is an analytical tool provided by Meta that helps measure the effectiveness of the bank's Facebook advertising. The Meta-pixel transferred and linked a website visitor's activity and behavior on the bank's website with a unique registered user of any of Meta's services. The purpose of implementing and using the Meta-pixel was to optimize the bank's marketing. The aim of the personal data processing was to use targeted advertising on Facebook and to market the bank to a relevant audience. The Meta-pixel enabled more relevant marketing to be developed by basing the marketing on information about which pages on the bank's website a person had visited.

Before the bank began its collaboration with Meta, an approval process was conducted involving the bank's functions in risk, compliance, legal, and information security. Within this process, issues regarding bank secrecy and personal data processing were addressed. Only data regarding a person's visited web pages, IP address, and information about certain unique events, such as product selections and searches on the website, were necessary to process for the intended purpose.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-5544

3(15)

Date: 2024-06-24

Activation of New Sub-Functions in the Meta Pixel

In 2019, Meta developed the service Meta Pixel by also providing the function Automatic Advanced Matching ("AAM"). This is a sub-function within the Meta Pixel. In addition to AAM, the Meta Pixel also offers the function Automatic Events ("AH"), which can be activated manually and then attempts on its own to detect and capture events and interactions, such as clicks, searches, and menu selections, during visits to the company's website or app.

In 2019, the bank's legal department received a request from the marketing department regarding the possibility of using one of Meta's functions through which customer data would be transferred to Meta. The bank's legal department found that the relevant function could not be implemented. Furthermore, it is the bank's view that if the implementation of a function such as AAM had been subject to internal processes and routines, it would have led to the assessment that the bank could not accept the terms and that it would not be possible to use the function. This is because the function risks involving a transfer of data to Meta that the bank cannot legally perform in its banking operations.

It has never been the bank's intention to use the functions AAM and AH. The bank has not been able to verify how the functions were activated. If the function was activated by any employee of the bank,

the bank's view is that it occurred by mistake. The bank has not made any decision to activate the function AAM.

The Bank's Transfer of Personal Data via the Function AAM to Meta

The Function Automatic Advanced Matching (AAM)

The AAM function transferred data in hashed form (using the hashing function SHA256) to Meta if the user filled out any of the five different forms on the bank's website or in the bank's mobile app. Two forms were in the new customer flow (open to visitors, where the visitor intended to become a customer). Three forms concerned mortgages and were behind a login, and could only transfer data from existing customers who had entered into a customer agreement with the bank. For the data to be transferred, it was therefore required that a person was logged into the bank's website and that the person had accepted marketing cookies from the bank. If these conditions were not met, AAM was not activated, and no data was transferred. If the conditions were met, the following hashed data could be transferred to Meta:

- Personal identification number
- Contact details, such as phone number, email address, postal code, and postal locality
- Loan amount on existing loan
- Employer
- Type of employment
- Account number

2 IMY's addition: Hashing is a cryptographic one-way function that can be used to achieve pseudonymization, which is a possible security measure under Article 32 of the General Data Protection Regulation, by replacing personal data with a so-called hash value. This means that the replaced personal data is not available in plaintext and that additional information is needed to identify the data subject.

Data Protection Authority

Case Number: DI-2021-5544

4(15)

Date: 2024-06-24

Due to the AAM function being unintentionally activated by the bank, the Meta pixel was able to match the hashed data with visitors' behavior on the website for profiling purposes. This allowed for a more detailed picture of the visitors. The profiling was solely related to the bank's marketing and was not used by Meta for its own or other parties' commercial purposes. The exact impact of AAM on advertising has not been established. It cannot be ruled out that this resulted in targeted advertising.

Function of Automatic Events (AH)

The AH function transmitted data in clear text to Meta when a user navigated on the bank's website or in the mobile app. A prerequisite for the transmission was that the user had consented to marketing cookies with the bank and was logged in as a customer of the bank (with one exception, see below). The data that was transmitted in clear text to Meta was done so unintentionally, as there was no intention to display the information to anyone other than the customer. The transmission occurred from the browser or app on the customer's device due to three main factors:

1) The function that was unintentionally activated by the bank at Meta also follows how a user moves on a site/in the mobile app (converts). To do this, information is sent about which "buttons" – that is, elements on the page/screen – the user presses while navigating on the site/in the app. Consequently, Meta collects information that indicates which button presses occur to understand the context in which the user converts. For example, Meta wants to understand that the customer is purchasing something

when pressing a button labeled "Buy," even if the advertiser has not tagged the purchase button as a conversion. This information was sent to Meta.

2) The bank uses elements that Meta perceives as buttons, such as button-marked boxes and dropdown menus, in its code to present certain information to the bank's users. This primarily applies when there are elements on the site/apps that can be pressed to, for example, show more information. Often, these are displayed as a smaller visual element that enlarges when pressed, thereby showing more information. When users have pressed these elements to see more information, it has been registered as regular button presses by Meta's script (Meta pixel's note IMY). The script then compiled the information and sent it to Meta as a registered button press.

3) Information about button presses is not pseudonymized (hashed IMY's note) by Meta in the same way as other information they collect.

These three factors together resulted in certain information being sent to Meta in clear text. It was thus a combination of the (incorrectly) activated functionality along with Meta's handling of button presses and a specific technical solution from the bank that caused the transmission to Meta.

In summary, AH analyzed which buttons on the website and mobile app the user pressed to then provide marketing suggestions on Facebook. The bank's transmission of data via AH occurred because the bank categorized visual fields as buttons in the website and mobile app code. Through AH, the following categories of data could be transmitted to Meta in clear text:

Swedish Data Protection Authority

Case Number: DI-2021-5544

5(15)

Date: 2024-06-24

- Securities holdings and value, such as available amount for purchases, withdrawals, and value development
- Information about loan amounts
- Account number and credit limit
- Fees, taxes, and current interest rates
- Ongoing orders and today's closures
- Authorized signatories and the bank from which the pension is transferred
- Email address and personal identification number

The majority of the information transferred via AH came from buttons behind the logged-in state at the bank, that is, buttons that were only displayed for customers who had entered into a customer agreement with the bank. However, at one location on the bank's website, there were expandable panels in the flow for subscribing to occupational pensions, both for sole proprietorships and for limited companies, which were open to all visitors, meaning also information from a limited number of visitors without a customer agreement with the bank and who were thus not logged in.

Actions taken after the personal data incident

Meta has confirmed to the bank that the personal data that was processed has been deleted at Meta in a manner that does not allow Meta to restore it.

The bank's view is that the transfer of the data did not cause any harm or risk to the data subjects since Meta did not use the data for its own purposes or transfer it further, and that the data has been deleted. All information has been transferred by the Meta pixel to Meta and the bank's own advertising account at Meta.

In order to detect outgoing traffic, the bank has now established a process for how the bank introduces

and manages third-party scripts. This describes how these scripts should be evaluated from a security and privacy perspective, as well as how they are maintained in the long term.

Furthermore, the bank has moved the scripts from third-party providers to the bank's own systems to avoid changes to the scripts being introduced without the bank's awareness.

The bank has also supplemented internal guidelines to more clearly describe the error scenario, how it is avoided, and what expectations are placed on the bank's development team when managing this type of product.

In addition, the bank has implemented further governing documents and procedures aimed at ensuring the correct processing of personal data. These governing documents include, among other things, requirements and guidelines in relation to the processing of personal data before, in connection with, and after the introduction of new features on the bank's website.

Justification of the decision

Applicable provisions, etc.

According to Article 95 of the General Data Protection Regulation, the General Data Protection Regulation shall not impose any additional obligations on natural or legal persons that process personal data, for such areas that are already covered by obligations.

Integrity Protection Authority

Diary Number: DI-2021-5544

6(15)

Date: 2024-06-24

according to the so-called ePrivacy Directive. The ePrivacy Directive has been implemented in Swedish law through the Act (2003:389) on Electronic Communication (LEK), which regulates, among other things, the collection of data through cookies.

According to Chapter 9, Section 28 of the LEK, which implements Article 5.3 of the ePrivacy Directive, data may be stored in or retrieved from a subscriber's or user's terminal equipment only if the subscriber or user has access to information about the purpose of the processing and consents to it. Furthermore, it is stated that this does not prevent such storage or access that is necessary for the transmission of an electronic message via an electronic communications network or that is necessary to provide a service that the user or subscriber has explicitly requested. The LEK entered into force on August 22, 2022. However, during the relevant period in this case, the same requirements applied according to Chapter 6, Section 18 of the Act (2003:389) on Electronic Communication. The Swedish Post and Telecom Authority is the supervisory authority according to the LEK (Chapter 1, Section 5 of the Regulation (2022:511) on Electronic Communication).

The European Data Protection Board (EDPB) has expressed its views on the interaction between the ePrivacy Directive and the General Data Protection Regulation (GDPR). The opinion states, among other things, that the national supervisory authority designated under the ePrivacy Directive is solely competent to monitor compliance with the directive. However, the supervisory authority under the GDPR is the competent supervisory authority for processing that is not specifically regulated in the ePrivacy Directive.

The data controller is, according to Article 4.7 of the GDPR, a natural or legal person, public authority, agency, or other body that alone or jointly with others determines the purposes and means of the processing of personal data. If the purposes and means of the processing are determined by Union law or the national law of the Member States, the data controller or the specific criteria for how they are to be designated may be provided for in Union law or in the national law of the Member States.

The data controller is responsible for and must be able to demonstrate that the fundamental principles in Article 5 of the GDPR are followed. This is stated in Article 5.2 of the GDPR (the principle of accountability).

According to Article 5.1(f) of the GDPR, personal data must be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures.

Article 32.1 of the GDPR states that the data controller must take appropriate technical and

organizational measures to ensure a level of security appropriate to the risk of the processing. In assessing what technical and organizational measures are appropriate, the data controller shall take into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing as well as the risks to the rights and freedoms of natural persons.

3 Directive 2002/58/EC of the European Parliament and of the Council of July 12, 2002, concerning the processing of personal data and the protection of privacy in the electronic communications sector (Directive on Privacy and Electronic Communications).

4 Opinion 5/2019 on the interaction between the Directive on Privacy and Electronic Communications and the General Data Protection Regulation, particularly regarding the competence, tasks, and powers of data protection authorities, adopted on March 12, 2019, paragraphs 68 and 69.

Integrity Protection Authority

Diary Number: DI-2021-5544

7(15)

Date: 2024-06-24

According to Article 32.1, appropriate security measures, where appropriate, include

- a) pseudonymization and encryption of personal data,
- b) the ability to ensure ongoing confidentiality, integrity, availability, and resilience of processing systems and services,
- c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident, and
- d) a procedure for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

According to Article 32.2 of the General Data Protection Regulation, when assessing the appropriate level of security, special consideration shall be given to the risks posed by the processing, in particular the risk of accidental or unlawful destruction, loss, or alteration, or of unauthorized disclosure of or access to personal data that has been transmitted, stored, or otherwise processed.

According to Chapter 3, Section 10 of the Act (2018:218) on supplementary provisions to the EU General Data Protection Regulation, personal identification numbers and coordination numbers may be processed without consent only when clearly justified in relation to the purpose of the processing, the importance of secure identification, or any other significant reason.

According to Chapter 1, Section 10, first paragraph of the Act (2004:297) on banking and financing operations (the Banking Act), individuals' relationships with credit institutions must not be unlawfully disclosed.

Assessment by the Integrity Protection Authority

The investigation in the matter shows that two functions in the analysis tool Meta-pixel were inadvertently activated by the bank. As a result of the activation of these functions, personal data about a large number of individuals who had logged into the bank's website or app were unlawfully transmitted to Meta. In some cases, personal data concerning individuals who visited the website or app and used a specific service without being logged in were also transmitted. Primarily, the bank's own customers have been affected by the transmission. The personal data transmitted included, among other things, personal identification numbers and extensive financial information. The information, including detailed data about customers' finances, has in several cases been transmitted in clear text.

According to the bank, it has not been possible to retrospectively verify how the functions were activated or by whom.

IMY initially assesses whether the General Data Protection Regulation is applicable and whether IMY is the competent supervisory authority.

IMY is the competent supervisory authority

IMY's review focuses on a situation where data about individuals, primarily customers who have logged into the bank, were inadvertently transmitted by the Meta-pixel to Meta in connection with their visit to various parts of the bank's website. This information handling does not involve data being

stored in or retrieved from a subscriber's or user's terminal equipment and is thus not covered by Chapter 9, Section 28 of the Electronic Communications Act (LEK) or the previously applicable corresponding provision in the Act (2003:389) on electronic communications. IMY thus concludes that the General Data Protection Regulation is

Data Protection Authority

Diary Number: DI-2021-5544

8(15)

Date: 2024-06-24

applicable to the current personal data processing and that IMY is the competent supervisory authority. It can further be noted that IMY's review concerns whether the bank has taken sufficient security measures, which is not specifically regulated in the LEK. This circumstance also means that IMY is the competent supervisory authority.

IMY then assesses the issue of data controller responsibility and whether the bank has taken appropriate security measures in accordance with Articles 5.1(f) and 32 of the General Data Protection Regulation (GDPR) to protect the personal data of affected website visitors and app users.

The Bank is the Data Controller

The bank has stated that it is the data controller for the personal data processing that has been reviewed in this case. The investigation shows that the purpose of implementing and using the Meta pixel has been to optimize the bank's marketing. By processing data about, for example, a person's visited web pages, searches, and product choices, the bank's marketing on Meta's service Facebook has thus been optimized.

IMY notes that the bank has determined the purposes and means for the processing of personal data, that is, how and why the personal data should be processed. IMY assesses that it is the bank that, according to Article 4.7 of the GDPR, is the data controller for the personal data processing covered by the supervision.

The processing has involved a high risk and required a high level of protection

According to Article 32 of the GDPR, the bank has an obligation to protect the personal data it processes by taking appropriate technical and organizational measures. The measures must ensure an appropriate level of security. In assessing what level of security is appropriate, the data controller must consider the costs, the nature, scope, context, and purposes of the processing, and the risks to the rights and freedoms of natural persons posed by the processing.

According to Chapter 1, Section 10, first paragraph of the Banking Act, anyone who is or has been associated with a bank may not unlawfully disclose information concerning a bank customer's dealings with the bank. The information regarding whether a certain person is a customer of the bank or not is also covered by the duty of confidentiality. These legal requirements regarding confidentiality thus apply in the bank's operations. This places high demands on the protection of the personal data processed in the bank's operations.

IMY notes that the data that has been handled has included particularly sensitive personal data, namely personal identification numbers, which may only be processed under certain conditions. There have also been economic data, such as account numbers, securities holdings, loan amounts, and credit limits, for which the data subjects have legitimate expectations of a high degree of confidentiality and robust protection against unauthorized access. The data that has been transferred has been subject to statutory confidentiality obligations. The personal data processing has occurred within the framework of the bank's core operations, which imposes even higher demands on the level of protection. The bank should have had a good ability to ensure security that was appropriate based on the scope and sensitivity of the processing.

Considering, among other things, that the data processed by the bank has been of a sensitive nature and has concerned a very large number of individuals, the bank's processing of personal data has overall posed a high risk to the rights and freedoms of natural persons.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-5544

9(15)

Date: 2024-06-24

rights and freedoms. The nature, scope, and context of the processing have thus resulted in a requirement for a high level of protection for the data. The measures should, among other things, ensure that personal data is protected against unauthorized disclosure and unauthorized access. The bank has not taken sufficient measures to protect the data.

IMY initially notes that the fact that the bank transferred the relevant data to Meta means that the data has, in fact, not been protected against unauthorized disclosure.

According to the bank's information, it has formalized procedures to ensure proper processing of personal data before, during, and after the introduction of new features on the website, and that these procedures are documented in the bank's governing documents.

IMY notes that the bank has thus had organizational measures in place in the form of procedures that have been documented in the bank's governing documents. However, in this particular case, the bank did not follow its procedures. The bank had the Meta pixel implemented on parts of the bank's website and app that were intended solely for logged-in customers and potential customers. The two functions AAM and AH in the Meta pixel were subsequently activated without the bank being aware of it. As a consequence of the bank not following its procedures during the implementation of these functions and not documenting what occurred, it has not been possible for the bank to retrospectively verify how or by whom these functions were activated.

As a result of the two functions AAM and AH being activated without the bank's knowledge, unauthorized disclosure of data that is subject to confidentiality and unauthorized transfer of personal data to Meta occurred. This continued for over a year and a half. The cessation of the disclosure and the unauthorized transfer was not due to the bank itself noticing what was happening, but rather because the bank became aware of it through an external source.

The bank has thus lacked the ability to detect the disclosure of and the ongoing transfer of personal data to Meta. IMY believes that the bank should have had such systematic security work that this would have been detected by the bank. Such security work includes that controls are performed with certain regularity.

Since the bank has only had procedures for following up documented changes that have been made according to established procedures, the bank has lacked the ability to detect and address changes that, as in this particular case, have been made without following the procedures. Against this background, IMY concludes that the bank has lacked technical and organizational security routines to systematically follow up and detect unintended changes in its systems.

As a result of the bank not applying its organizational security routines when the bank implemented the functions AAM and AH, and lacking organizational and technical security routines to detect transfers, personal data about a large number of individuals has been unlawfully transferred to Meta. The investigation shows that it has involved personal data about approximately 500,000 – 1,000,000 individuals.

In summary, IMY concludes that the bank, in its use of the Meta pixel, has not taken sufficient technical and organizational measures to ensure a level of security that has been appropriate in relation to the risk. This means that the bank during

Swedish Authority for Privacy Protection

Diary Number: DI-2021-5544

10(15)

Date: 2024-06-24

During the period from November 15, 2019, to June 2, 2021, personal data has been processed in violation of Article 32.1 of the General Data Protection Regulation. According to the fundamental security principle in Article 5.1 f of the General Data Protection Regulation, personal data must be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against loss, destruction, or damage through accidental means, using appropriate technical or organizational measures. Due to the incident, data concerning the bank's customers, such as personal identification numbers, account numbers, securities holdings, loan amounts, and credit limits, have been transmitted to Meta in plaintext.

Furthermore, certain data has been transmitted in hashed form, which has enabled matching with personal data at Meta. This has involved data that is subject to statutory confidentiality obligations. Loss of control over bank information can pose a high risk to the rights and freedoms of the data subjects. The fact that the matter concerns bank information and that the personal data has predominantly been disclosed and transmitted in plaintext from a logged-in state for customers means, according to IMY, that the incident is particularly serious. The bank's failure to follow its formalized procedures and its inability to detect the unauthorized transfer of personal data is therefore assessed to be of such a serious nature that the deficiency also constitutes a violation of Article 5.1 f of the General Data Protection Regulation.

Choice of Intervention

Legal Regulation

IMY has a number of corrective powers in the event of violations of the General Data Protection Regulation, including reprimands, orders, and administrative fines. This follows from Article 58.2 a–j of the General Data Protection Regulation. IMY shall impose administrative fines in addition to or instead of other corrective measures referred to in Article 58.2, depending on the circumstances of each individual case.

Each supervisory authority shall ensure that the imposition of administrative fines in each individual case is effective, proportionate, and dissuasive. This is stated in Article 83.1 of the General Data Protection Regulation.

Article 83.2 specifies the factors to be considered in determining whether an administrative fine should be imposed and what may affect the amount of the fine. Relevant for the assessment of the seriousness of the violation are, among other things, its nature, severity, and duration.

According to Article 83.4, in the event of violations of, among other things, Article 32, administrative fines of up to 10,000,000 EUR or, if it concerns a company, up to two percent of the total global annual turnover during the previous financial year, whichever is higher, shall be imposed.

According to Article 83.5, in the event of violations of, among other things, Article 5, administrative fines of up to 20,000,000 EUR or, if it concerns a company, up to four percent of the total global annual turnover during the previous financial year, whichever is higher, shall be imposed.

Integrity Protection Authority

Diary Number: DI-2021-5544

11(15)

Date: 2024-06-24

The EDPB has adopted guidelines on the calculation of administrative fines under the Data Protection Regulation aimed at creating a harmonized method and principles for calculating fines.⁵

In the case of a minor infringement, IMY may, as stated in Recital 148, instead of imposing an administrative fine, issue a reprimand in accordance with Article 58.2 b of the Regulation.

IMY's Assessment

Administrative Fine to be Imposed

IMY has assessed that the bank has processed personal data in violation of Article 32.1 of the Data Protection Regulation and that the infringement is of such a serious nature that it also constitutes a violation of the principles of integrity and confidentiality in Article 5.1 f.

The infringement has occurred because the bank processed personal data with an insufficient level of security, which has resulted in, among other things, financial data about approximately 500,000 - 1,000,000 individuals being unlawfully transferred to Meta over a period of more than one and a half years. Furthermore, the bank lacked the ability to detect the transfer of personal data to Meta during this time. IMY believes that the bank should have had such systematic security measures in place that the transfer of personal data would have been detected during a regular check. The unauthorized transfer has posed a high risk to the rights and freedoms of the data subjects, particularly regarding the loss of confidentiality for sensitive data. Against this background, IMY assesses that this is not a case of the minor infringements referred to in Recital 148 of the Data Protection Regulation.

The Court of Justice of the European Union has clarified that it is required that the data controller has committed an infringement intentionally or negligently for administrative fines to be imposed under the Data Protection Regulation. The Court has stated that data controllers can be imposed fines for actions if they cannot be considered to have been unaware that the actions constituted an infringement, regardless of whether they were aware that they were violating the provisions of the Data Protection Regulation.⁶

According to the principle of accountability, which is expressed in Article 5.2 of the Data Protection Regulation, those responsible for the processing of personal data must ensure and be able to demonstrate that the processing is in compliance with the Data Protection Regulation.

IMY thus notes that the bank is responsible for ensuring that the personal data processed in its operations is handled in a manner that ensures an appropriate level of security. IMY has found in its assessment that the bank has not met the requirements set by the Data Protection Regulation in this regard. The bank cannot be considered to have been unaware that its actions constituted a violation of the Regulation.

5 EDPB Guidelines 04/2022 on the calculation of administrative fines under the GDPR, adopted on May 24, 2023.

6 Judgment of the Court of Justice of the European Union in Case C-683/21 *Nacionalinis visuomenės sveikatos centras prie Sveikatos apsaugos ministerijos v. Valstybinė duomenų apsaugos inspekcija* of December 5, 2023, paragraph 81, and judgment in Case C 807/21 *Deutsche Wohnen* of December 5, 2023, paragraph 76.

Swedish Data Protection Authority

Diary Number: DI-2021-5544

12(15)

Date: 2024-06-24

Thereby, the conditions exist to impose an administrative sanction fee on the bank.⁷

In determining the amount of the sanction fee, IMY shall consider the circumstances specified in Article 83.2 and ensure that the administrative sanction fee is effective, proportionate, and deterrent.

IMY notes that violations of Article 5.1 f of the General Data Protection Regulation are covered by Article 83.5, which means that a sanction fee of up to twenty million euros or four percent of the global annual turnover from the previous budget year, whichever is higher, may be imposed.

The annual turnover of the Avanza Group according to the consolidated financial statements of the parent company shall be the basis for the calculation.

In determining the maximum amount for a sanction fee to be imposed on a company, the definition of the term "company" used by the Court of Justice of the European Union in the application of Articles 101 and 102 of the Treaty on the Functioning of the European Union (see Recital 150 of the General Data Protection Regulation) shall be applied. The case law indicates that this includes any entity engaged in economic activity, regardless of the legal form of the entity and the manner of its financing, even if the entity legally consists of several natural or legal persons.

The assessment of what constitutes a company shall thus be based on the definitions from competition law. The rules for group liability in EU competition law revolve around the concept of an economic unit.

A parent company and a subsidiary are considered part of the same economic unit when the parent company exercises decisive influence over the subsidiary. The decisive influence (i.e., control) can be achieved either through ownership or through agreements. Case law indicates that 100 percent or nearly 100 percent ownership creates a presumption that control is deemed to exist. However, this presumption can be rebutted if the company provides sufficient evidence to demonstrate that the subsidiary operates independently in the market.⁸ To rebut the presumption, the company must provide evidence regarding the organizational, economic, and legal connections between the subsidiary and its parent company that shows they do not constitute an economic unit, despite the parent company holding 100 percent or nearly 100 percent of the shares.⁹

Avanza Bank AB is a wholly-owned subsidiary of the parent company Avanza Bank Holding AB (publ). According to the presumption described above, it is therefore the turnover of the Avanza Group

according to the consolidated financial statements of Avanza Bank Holding AB (publ) that shall be the basis for calculating the maximum sanction fee amount.

According to the consolidated financial statements of Avanza Bank Holding AB for 2023, the total global annual turnover was approximately 4,716,000,000 SEK. Four percent of that annual turnover is approximately 189,000,000 SEK. Since this amount is below the maximum amount specified in Article 83.5, the highest sanction amount that can be determined in this case is 20,000,000 euros.

7 See for the assessment of negligence also the Administrative Court of Appeal in Stockholm's judgment on March 11, 2024, in case 2829-23 p.12.

8 Judgment of the Court of Justice of the European Union in case C-97/08 P Akzo Nobel NV et al. against the EU Commission on September 10, 2009, paragraphs 59-61. Adjust/insert footnotes where we refer to the judgments of the Court of Justice of the European Union.

9 Cf. EDPB Guidelines 04/2022 on the calculation of administrative fines under the GDPR, paragraph 125 and the decisions presented therein.

Swedish Data Protection Authority

Case Number: DI-2021-5544

Page 13 of 15

Date: 2024-06-24

Severity of the Violation

According to the EDPB's guidelines, the supervisory authority must assess whether the violation is of low, medium, or high severity.¹⁰

IMY assesses that the following factors are significant for the evaluation of the severity of the violation. IMY has determined that the bank did not follow its procedures when the functions AAM and AH in the Meta pixel were activated and that the bank lacked the systematic security work required to detect the unauthorized disclosure and transfer of personal data to Meta. The relevant security deficiencies have led to an incident affecting a large number of data subjects, and Meta has been able to access a substantial amount of personal data, in many cases in plain text, that should not have been transferred to Meta. The data included financial information and personal identification numbers, i.e., data that requires a high level of protection. The violation has persisted for an extended period, from November 15, 2019, until June 2, 2021, when the bank became aware of the unauthorized transfer of the data. The processing of personal data on the bank's website is part of the bank's core operations, where the data is subject to statutory confidentiality, which means that the violation should be considered more serious than if this were not the case.¹¹

IMY has determined that the violation is so serious that it constitutes not only a breach of Article 32.1 of the General Data Protection Regulation but also a violation of the fundamental principle of integrity and confidentiality under Article 5.1 f. IMY assesses overall that the current violation has a low severity level within the range of violations of Article 5.1 f.

In its assessment of the size of the administrative fine, IMY must also take into account aggravating and mitigating factors listed in Article 83.2 of the General Data Protection Regulation. IMY notes that the bank has taken certain measures to mitigate the harm suffered by the data subjects according to Article 83.2 c. The bank immediately disabled the pixel functions when it became aware of the transfer. The bank also contacted Meta to ensure that Meta had not processed the data for its own purposes and that the data had been deleted by Meta. In addition, the bank has implemented further governing documents and procedures aimed at ensuring proper processing of personal data. IMY assesses that the bank, through these measures, has done what could be expected given the nature, purpose, and scope of the processing. The measures taken therefore do not constitute a mitigating factor. IMY notes that no other circumstances have emerged that affect IMY's assessment of the size of the administrative fine, either in an aggravating or mitigating direction.

The administrative fine must be effective, proportionate, and deterrent

The administrative fine must be effective, proportionate, and deterrent. This means that the amount must be determined so that the administrative fine leads to rectification, provides a preventive effect, and is also proportionate in relation to both the current violations and the supervisory subject's ability to pay.

10 EDPB's guidelines Guidelines 04/2022 on the calculation of administrative fines under the GDPR, point 60.

11 EDPB's guidelines Guidelines 04/2022 on the calculation of administrative fines under the GDPR, point 53.

Swedish Data Protection Authority

Case Number: DI-2021-5544

Page 14 of 15

Date: 2024-06-24

In light of the severity of the violation, IMY determines that the bank shall pay an administrative fine of 15,000,000 SEK for the identified violations. IMY assesses that this amount is effective, proportionate, and deterrent.

This decision has been made by Acting Director General David Törngren after presentation by Senior Lawyer Hans Kärnlöf. In the final processing, Acting Legal Director Cecilia Agnehall and Unit Manager Catharina Fernquist, as well as IT and Information Security Specialist Petter Flink, have also participated.

David Törngren, 2024-06-24 (This is an electronic signature)

Copy to

DSO

Swedish Data Protection Authority

Case Number: DI-2021-5544

Page 15 of 15

Date: 2024-06-24

How to Appeal

If you wish to appeal the decision, you must write to the Swedish Data Protection Authority. Indicate in your letter which decision you are appealing and the change you are requesting. The appeal must be received by the Swedish Data Protection Authority no later than three weeks from the day you received notice of the decision. If the appeal is submitted in a timely manner, the Swedish Data Protection Authority will forward it to the Administrative Court in Stockholm for examination.

You may email the appeal to the Swedish Data Protection Authority if it does not contain any privacy-sensitive personal data or information that may be subject to confidentiality. The authority's contact details are provided on the first page of the decision.